4Geeks

Proyecto Final

Análisis forense de servidor WordPress comprometido

Realizado por: Futuro Especialista en ciberseguridad graduado de 4geeks: Fabrizio Bautista Jimenez

Alcance y metodologia

Proyecto ejecutado en tres frentes: analisis forense, explotacion de una vulnerabilidad distinta y diseno de controles de gestion

Ruta de trabajo

Fase 1

Reconocimiento, levantamiento inicial, evidencias, procesos, logs y superficie expuesta.

Fase 2

Deteccion, explotacion controlada y mitigacion de una vulnerabilidad distinta al acceso original.

Fase 3

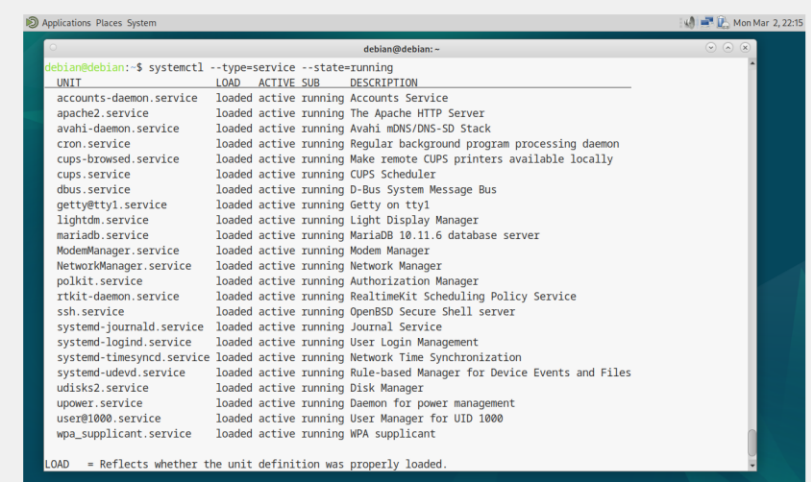
Plan de respuesta, proteccion de datos, recuperacion e ISMS basado en ISO 27001.

Herramientas: logs del sistema/SSH, inventario de servicios y validaciones con Nmap + curl.

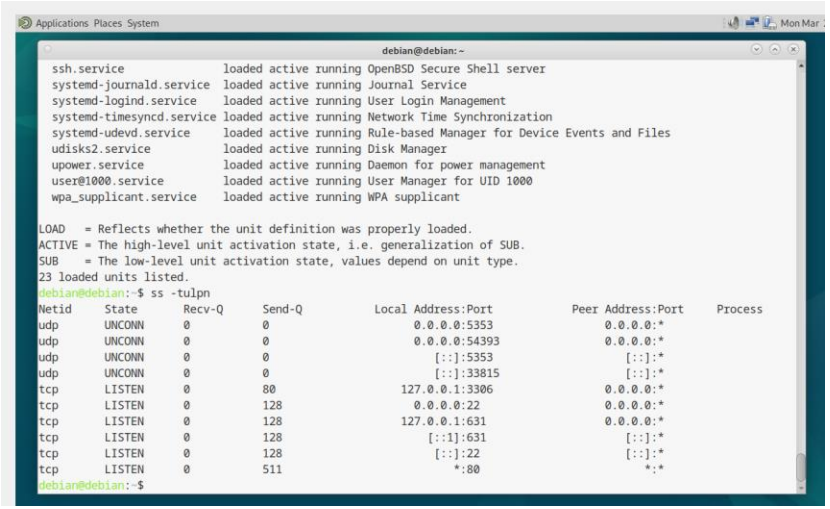
Evidencia inicial del sistema

Levantamiento base antes de aplicar cambios de seguridad

Revisión del access.log de Apache



Inventario de servicios en ejecución



Puertos en escucha

Que se confirmo

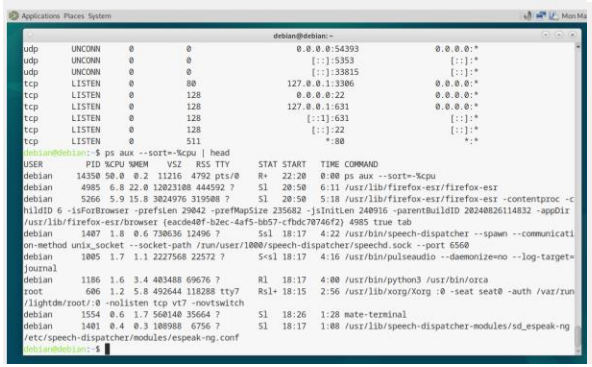
- Software Apache, SSH y MariaDB estaban activos; la base de datos escuchaba solo en localhost:3306.
- El access.log reflejaba actividad esperada del panel y peticiones internas de WordPress.
- Esta linea base permitio separar exposicion real a red de servicios visibles solo de forma local.

Valor para la investigacion

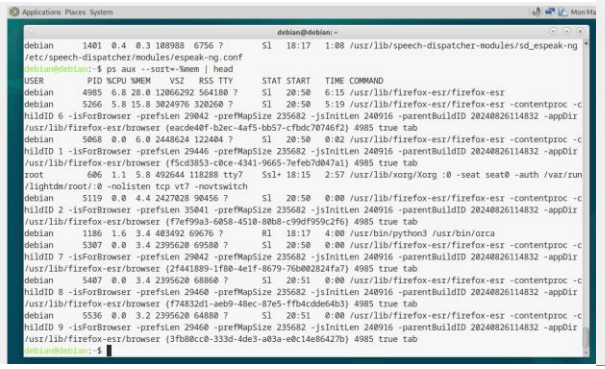
Este paso le dio contexto al resto del hardening.

Servicios expuestos y endurecimiento de SSH

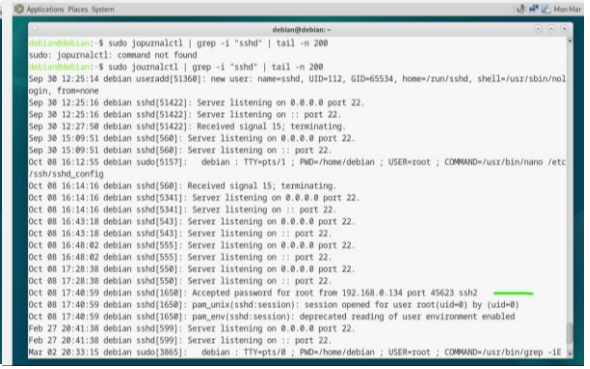
Se reviso la evidencia historica y luego se limito el acceso remoto a lo estrictamente necesario



Procesos con mayor consumo de CPU



Procesos con mayor consumo de memoria



Evidencia de conexiones ssh

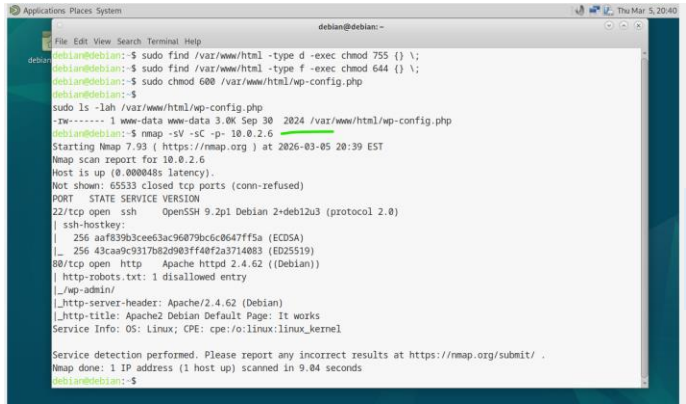
Objetivo: reducir superficie sin cortar servicio

```
debian@debian:~$ sudo ss -lntup | egrep ":21|vsftpd"
tcp   LISTEN 0      32                 *:21               *:*    users:(("vsftpd",pid=561,fd=3))
debian@debian:~$ sudo egrep -n "^(listen|listen_ipv6|anonymous_enable|local_enable|write_enable|chroot_local_user|u
serlist_enable|pasv_|ssl_|pam_service_name)" /etc/vsftpd.conf
14:listen=NO
22:listen_ipv6=YES
25:anonymous_enable=YES
28:local_enable=YES
31:write_enable=YES
145:pam_service_name=vsftpd
151:ssl_enable=NO
debian@debian:~$
```

Se encuentra servicio vsftpd y mala config ssh

Hardening de SSH: sin root por contraseña y con llave pública

Resultado: acceso remoto mas controlado



Nmap para validar que siga corriendo el puerto 22

Decisiones de seguridad

- Se justifico el hardening revisando accesos SSH previos.
- Se desactivo root por contrasena y se forzo autenticacion con llave publica.
- La validacion posterior dejo como superficie principal solo 22/tcp y 80/tcp.

Revision del sitio WordPress y busqueda de persistencia

Se inspeccionaron componentes sensibles de WordPress y puntos tipicos de backdoor

```
debian@debian:~$ sudo stat /var/www/html
[sudo] password for debian:
  File: /var/www/html
  Size: 4096            Blocks: 8          IO Block: 4096   directory
Device: 8,1     Inode: 170982      Links: 5
Access: (0777/drwxrwxrwx)  Uid: (   33/www-data)   Gid: (   33/www-data)
Access: 2026-03-05 01:18:34.236743153 -0500
Modify: 2026-03-03 23:20:12.021703351 -0500
Change: 2026-03-03 23:20:12.021703351 -0500
 Birth: 2024-09-30 10:44:18.817368266 -0400
debian@debian:~$ sudo stat /var/www/
  File: /var/www/
  Size: 4096            Blocks: 8          IO Block: 4096   directory
Device: 8,1     Inode: 170981      Links: 3
Access: (0755/drwxr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
Access: 2026-03-05 01:17:59.972882607 -0500
Modify: 2024-09-30 10:44:18.817368266 -0400
Change: 2024-09-30 10:44:18.817368266 -0400
 Birth: 2024-09-30 10:44:18.817368266 -0400
debian@debian:~$ sudo ls -lah /var/www/
total 12K
drwxr-xr-x  3 root     root     4.0K Sep 30  2024 .
drwxr-xr-x 12 root     root     4.0K Sep 30  2024 ..
drwxrwxrwx  5 www-data www-data 4.0K Mar  3 23:20 html
```

Estructura principal /var/www/html

```
root@debian:/home/debian# sudo ls -lah /var/www/html/wp-config.php
-rwxr-xr-x 1 www-data www-data 3.0K Mar  6 02:42 /var/www/html/wp-config.php
root@debian:/home/debian# sudo chmod 600 /var/www/html/wp-config.php
root@debian:/home/debian# sudo ls -lah /var/www/html/wp-config.php
-rw------- 1 www-data www-data 3.0K Mar  6 02:42 /var/www/html/wp-config.php
root@debian:/home/debian#
```

Permisos iniciales observados

```
debian@debian:~$ sudo ls -lah /var/www/html | head -n 60
[sudo] password for debian:
total 264K
drwxrwxrwx  5 www-data www-data 4.0K Mar  3 23:20 .
drwxr-xr-x  3 root     root     4.0K Sep 30  2024 ..
-rwxrwxrwx  1 www-data www-data  523 Sep 30  2024 .htaccess
-rwxrwxrwx  1 www-data www-data  11K Sep 30  2024 index.html
-rwxrwxrwx  1 www-data www-data  405 Feb  6  2020 index.php
-rwxrwxrwx  1 www-data www-data  20K Mar  3 23:20 license.txt
-rwxrwxrwx  1 www-data www-data 7.3K Mar  3 23:20 readme.html
-rwxrwxrwx  1 www-data www-data 7.2K Mar  3 23:20 wp-activate.php
drwxrwxrwx  9 www-data www-data 4.0K Sep 10  2024 wp-admin
-rwxrwxrwx  1 www-data www-data  351 Feb  6  2020 wp-blog-header.php
-rwxrwxrwx  1 www-data www-data 2.3K Jun 14  2023 wp-comments-post.php
-rwxrwxrwx  1 www-data www-data 3.0K Sep 30  2024 wp-config.php
-rwxrwxrwx  1 www-data www-data 3.3K Mar  3 23:20 wp-config-sample.php
drwxrwxrwx  6 www-data www-data 4.0K Mar  5 01:55 wp-content
-rwxrwxrwx  1 www-data www-data 5.5K Mar  3 23:20 wp-cron.php
drwxrwxrwx 31 www-data www-data  16K Mar  3 23:20 wp-includes
-rwxrwxrwx  1 www-data www-data 2.5K Mar  3 23:20 wp-links-opml.php
-rwxrwxrwx  1 www-data www-data 3.9K Mar 11  2024 wp-load.php
-rwxrwxrwx  1 www-data www-data  51K Mar  3 23:20 wp-login.php
-rwxrwxrwx  1 www-data www-data 8.6K Mar  3 23:20 wp-mail.php
-rwxrwxrwx  1 www-data www-data  31K Mar  3 23:20 wp-settings.php
```

Archivos modificados recientemente

```
/usr/lib/firefox-esr/browser {3fb80cc0-333d-4de3-a03a-e0c14e86427b} 4985 true tab
debian@debian:~$ ls -la /var/www/html
total 256
drwxrwxrwx  5 www-data www-data  4096 Oct  8  2024 .
drwxr-xr-x  3 root     root      4096 Sep 30  2024 ..
-rwxrwxrwx  1 www-data www-data   523 Sep 30  2024 .htaccess
-rwxrwxrwx  1 www-data www-data 10701 Sep 30  2024 index.html
-rwxrwxrwx  1 www-data www-data   405 Feb  6  2020 index.php
-rwxrwxrwx  1 www-data www-data 19915 Dec 31  2023 license.txt
-rwxrwxrwx  1 www-data www-data  7409 Jun 18  2024 readme.html
-rwxrwxrwx  1 www-data www-data  7387 Feb 13  2024 wp-activate.php
drwxrwxrwx  9 www-data www-data  4096 Sep 10  2024 wp-admin
-rwxrwxrwx  1 www-data www-data   351 Feb  6  2020 wp-blog-header.php
-rwxrwxrwx  1 www-data www-data  2323 Jun 14  2023 wp-comments-post.php
-rwxrwxrwx  1 www-data www-data  3017 Sep 30  2024 wp-config.php
drwxrwxrwx  5 www-data www-data  4096 Oct  8  2024 wp-content
-rwxrwxrwx  1 www-data www-data  5638 May 30  2023 wp-cron.php
drwxrwxrwx 30 www-data www-data 12288 Sep 10  2024 wp-includes
-rwxrwxrwx  1 www-data www-data  2502 Nov 26  2022 wp-links-opml.php
-rwxrwxrwx  1 www-data www-data  3937 Mar 11  2024 wp-load.php
-rwxrwxrwx  1 www-data www-data 51238 May 28  2024 wp-login.php
-rwxrwxrwx  1 www-data www-data  8525 Sep 16  2023 wp-mail.php
-rwxrwxrwx  1 www-data www-data 28774 Jul  9  2024 wp-settings.php
-rwxrwxrwx  1 www-data www-data 34385 Jun 19  2023 wp-signup.php
-rwxrwxrwx  1 www-data www-data  4885 Jun 22  2023 wp-trackback.php
-rwxrwxrwx  1 www-data www-data  3246 Mar  2  2024 xmlrpc.php
debian@debian:~$
```

```
GNU nano 7.2                    /var/www/html/wp-config.php *
*/

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wordpressuser' );

/** Database password */
define( 'DB_PASSWORD', 'ubQM2RhPU60v9g4+tkKnUGeZHeMY8laP' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+
```

Cambios de config.php

Conclusiones operativas

- Se separaron archivos esperados del core frente a cambios recientes.
- No se encontro evidencia concluyente de webshell activa en uploads.
- Si se detecto necesidad de normalizar permisos y revisar persistencia en cron y servicios.

Revision del sitio WordPress y busqueda de persistencia

```
debian@debian:~$ sudo find /var/www/html/wp-content -type f \( -name "*.php" -o -name "*.phtml" -o -name "*.php5" \
) -printf "%TY-%Tm-%Td %TT %p\n" | tail -n 80
sudo grep -RniE "(eval\(|base64_decode\(|gzinflate\(|shell_exec\(|system\(|passthru\()" /var/www/html/wp-content 2>
/dev/null | head -n 80
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/text-faq.php
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/posts-images-only-3-col.ph
p
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/text-alternating-images.ph
p
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/page-portfolio-overview.ph
p
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/posts-grid-2-col.php
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/text-centered-statement.ph
p
2024-05-06 16:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/banner-project-description
.php
2023-10-16 22:14:24.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/patterns/hidden-post-navigation.php
2024-02-07 14:45:12.0000000000 /var/www/html/wp-content/themes/twentytwentyfour/functions.php
2023-09-08 06:03:21.0000000000 /var/www/html/wp-content/themes/twentytwentytwo/functions.php
2022-01-11 10:58:02.0000000000 /var/www/html/wp-content/themes/twentytwentytwo/inc/patterns/header-logo-navigation-
offset-tagline.php
2024-02-08 14:32:15.0000000000 /var/www/html/wp-content/themes/twentytwentytwo/inc/patterns/page-about-media-right.
php
2022-01-11 10:58:02.0000000000 /var/www/html/wp-content/themes/twentytwentytwo/inc/patterns/header-with-tagline.php
```

Búsqueda de patrones típicos de backdoor/webshell

```
debian@debian:~$ sudo ls -lah /var/www/html/wp-content | head -n 80
sudo find /var/www/html/wp-content -maxdepth 2 -type d
total 28K
drwxr-xr-x 6 www-data www-data 4.0K Mar  5 01:55 .
drwxr-xr-x 5 www-data www-data 4.0K Mar  3 23:20 ..
-rw-r--r-- 1 www-data www-data   28 Jan  8  2012 index.php
drwxr-xr-x 3 www-data www-data 4.0K Mar  5 01:55 plugins
drwxr-xr-x 6 www-data www-data 4.0K Mar  5 01:55 themes
drwxr-xr-x 2 www-data www-data 4.0K Mar  3 23:20 upgrade
drwxr-xr-x 4 www-data www-data 4.0K Mar  3 23:20 uploads
/var/www/html/wp-content
/var/www/html/wp-content/uploads
/var/www/html/wp-content/uploads/2024
/var/www/html/wp-content/uploads/2026
/var/www/html/wp-content/plugins
/var/www/html/wp-content/plugins/akismet
/var/www/html/wp-content/themes
/var/www/html/wp-content/themes/twentytwentythree
/var/www/html/wp-content/themes/twentytwentyfive
/var/www/html/wp-content/themes/twentytwentyfour
/var/www/html/wp-content/themes/twentytwentytwo
```

Inspección de wp-content y uploads(permisos mal)

```
debian@debian:~$ sudo crontab -l 2>/dev/null
debian@debian:~$ sudo ls -lah /etc/cron.* /var/spool/cron 2>/dev/null
/etc/cron.d:
total 24K
drwxr-xr-x   2 root root 4.0K Sep 30  2024 .
drwxr-xr-x 120 root root 4.0K Mar  5 19:39 ..
-rw-r--r--   1 root root  285 Jan 10  2023 anacron
-rw-r--r--   1 root root  201 Mar  4  2023 e2scrub_all
-rw-r--r--   1 root root  712 Jul 13  2022 php
-rw-r--r--   1 root root  102 Mar  2  2023 .placeholder

/etc/cron.daily:
total 36K
drwxr-xr-x   2 root root 4.0K Sep 30  2024 .
drwxr-xr-x 120 root root 4.0K Mar  5 19:39 ..
-rwxr-xr-x   1 root root  311 Jan 10  2023 0anacron
-rwxr-xr-x   1 root root  539 Jul  1  2024 apache2
-rwxr-xr-x   1 root root 1.5K May 25  2023 apt-compat
-rwxr-xr-x   1 root root  123 Mar 26  2023 dpkg
-rwxr-xr-x   1 root root  377 Dec 14  2022 logrotate
-rwxr-xr-x   1 root root 1.4K Mar 12  2023 man-db
-rw-r--r--   1 root root  102 Mar  2  2023 .placeholder

/etc/cron.hourly:
total 12K
drwxr-xr-x   2 root root 4.0K Jul 31  2024 .
```

Revisión de cron y tareas automáticas

```
debian@debian:~$ sudo systemctl list-unit-files --type=service --state=enabled | head -n 80
UNIT FILE                          STATE   PRESET
accounts-daemon.service            enabled enabled
anacron.service                    enabled enabled
apache2.service                    enabled enabled
apparmor.service                   enabled enabled
avahi-daemon.service               enabled enabled
bluetooth.service                  enabled enabled
console-setup.service              enabled enabled
cron.service                       enabled enabled
cups-browsed.service               enabled enabled
cups.service                       enabled enabled
e2scrub_reap.service               enabled enabled
getty@.service                     enabled enabled
keyboard-setup.service             enabled enabled
lightdm.service                    enabled enabled
mariadb.service                    enabled enabled
ModemManager.service               enabled enabled
networking.service                 enabled enabled
NetworkManager-dispatcher.service  enabled enabled
NetworkManager-wait-online.service enabled enabled
NetworkManager.service             enabled enabled
ssh.service                        enabled enabled
systemd-pstore.service             enabled enabled
systemd-timesyncd.service          enabled enabled
udisks2.service                    enabled enabled
```

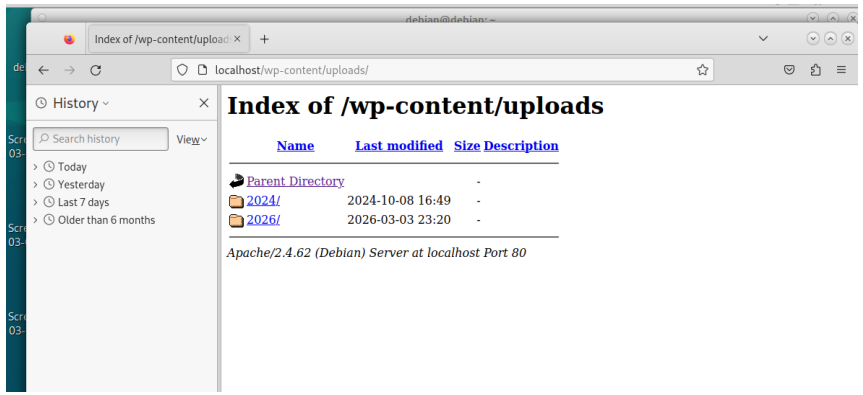
Servicios habilitados: búsqueda de persistencia

```
debian@debian:~$ sudo ls -lah /var/www/html/wp-content | head -n 80
total 28K
drwxr-xr-x 6 www-data www-data 4.0K Mar  5 01:55 .
drwxr-xr-x 5 www-data www-data 4.0K Mar  3 23:20 ..
-rw-r--r-- 1 www-data www-data   28 Jan  8  2012 index.php
drwxr-xr-x 3 www-data www-data 4.0K Mar  5 01:55 plugins
drwxr-xr-x 6 www-data www-data 4.0K Mar  5 01:55 themes
drwxr-xr-x 2 www-data www-data 4.0K Mar  3 23:20 upgrade
drwxr-xr-x 4 www-data www-data 4.0K Mar  3 23:20 uploads
debian@debian:~$ sudo find /var/www/html/wp-content -maxdepth 2 -type d
/var/www/html/wp-content
/var/www/html/wp-content/uploads
/var/www/html/wp-content/uploads/2024
/var/www/html/wp-content/uploads/2026
/var/www/html/wp-content/plugins
/var/www/html/wp-content/plugins/akismet
/var/www/html/wp-content/themes
/var/www/html/wp-content/themes/twentytwentythree
/var/www/html/wp-content/themes/twentytwentyfive
/var/www/html/wp-content/themes/twentytwentyfour
/var/www/html/wp-content/themes/twentytwentytwo
/var/www/html/wp-content/upgrade
debian@debian:~$ sudo find /var/www/html/wp-content/uploads -type f \( -name "*.php" -o -name "*.phtml" -o -name "*
.php5" \) -ls 2>/dev/null
debian@debian:~$
```

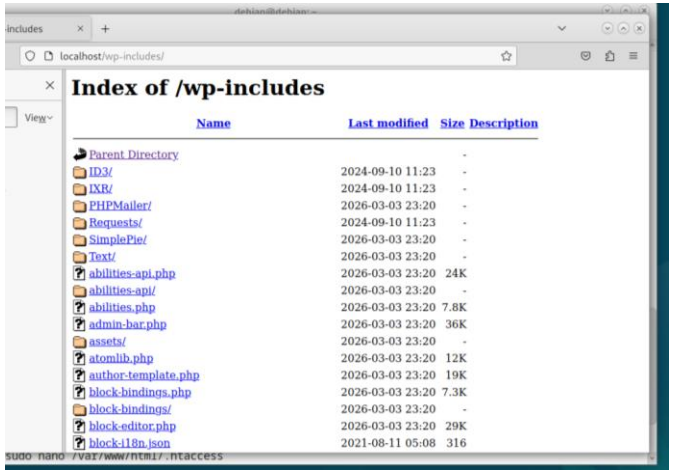
Resultado negativo en uploads para .php/.phtml/.php5

Vulnerabilidad explotada distinta: directory listing habilitado

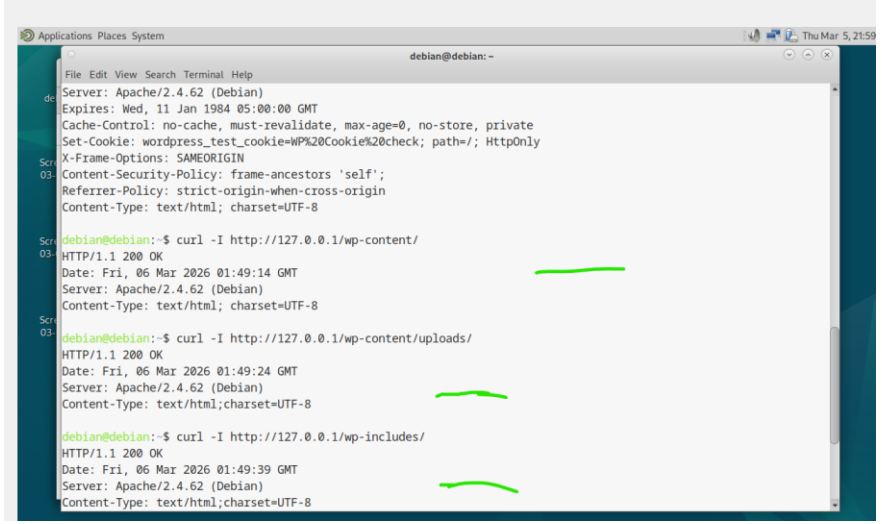
Apache exponia estructura interna del sitio y facilitaba reconocimiento al atacante



Index of/wp-content/uploads



Index of /wp-includes



Validación con curl: HTTP 200 OK

Riesgo observado

- El servidor permitia ver rutas como /wp-content/uploads y /wp-includes.(con esto se pueden ver orden de carpetas, estructura interna del sitio, pistas de como esta organizado wordpress)
- La respuesta HTTP 200 confirmaba que el listado era navegable y explotable.
- Esto entregaba nombres de carpetas, estructura interna y pistas utiles para ataques posteriores.

Impacto

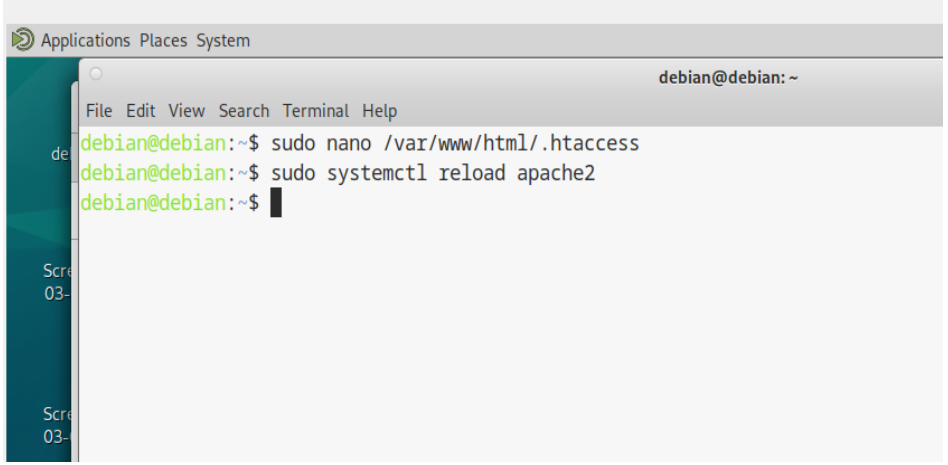
Reconocimiento mas rapido y exposicion innecesaria de artefactos web.

Severidad

Media-Alta por apoyo directo a la fase de descubrimiento.

Mitigacion aplicada y hardening adicional

Se corrigio Apache, se validaron respuestas 403 y se endurecieron permisos del sitio

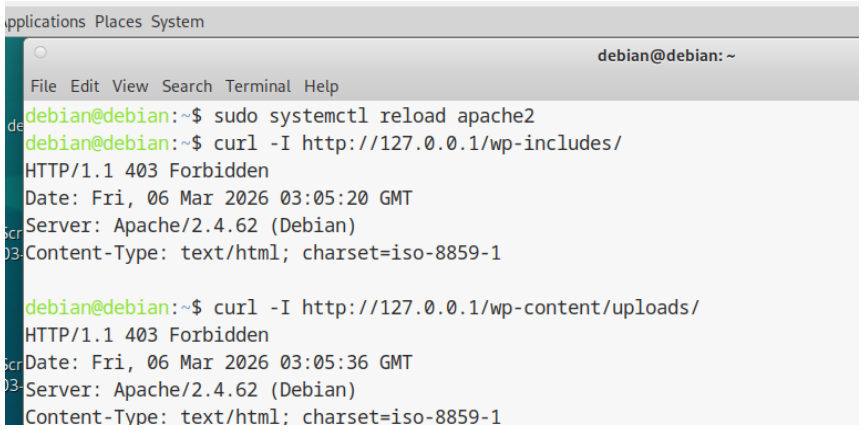


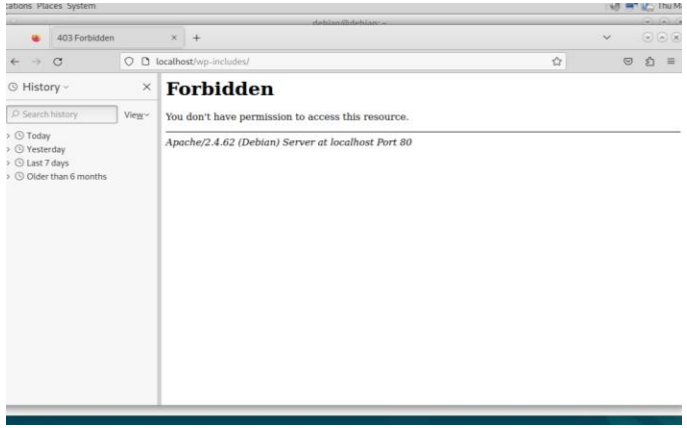
Se modifica /var/www/html/.htaccess

Resultado de la remediacion

- Se agrego Options -Indexes para impedir listados de directorios.
- Las comprobaciones posteriores devolvieron 403 Forbidden en rutas sensibles.
- El ajuste de permisos redujo lectura indebida sin romper la aplicacion.

Se agregó Options-Indexes en .htaccess

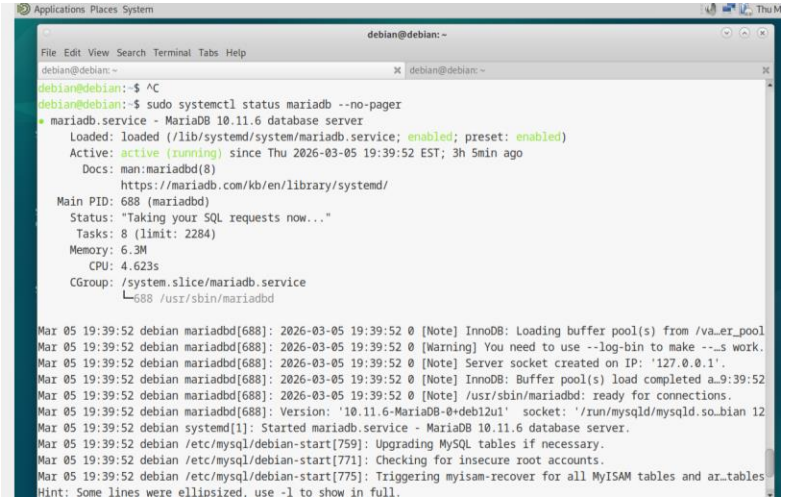




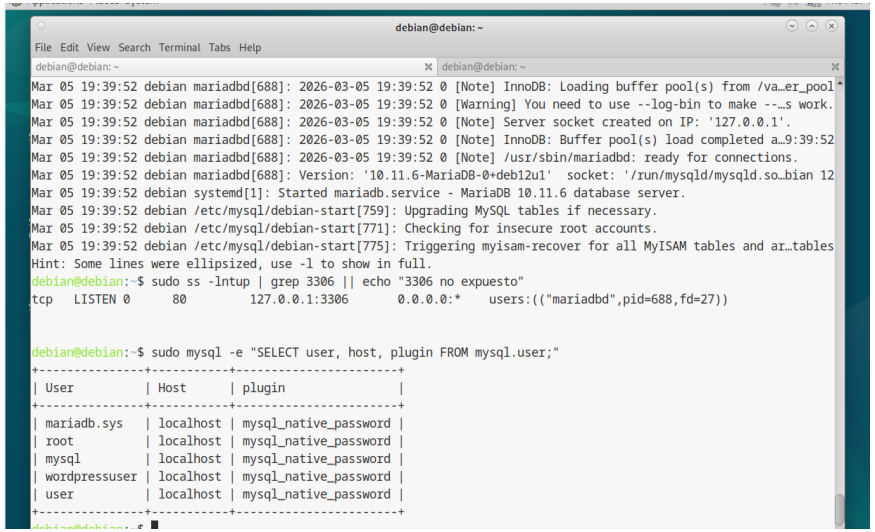
Comprobación final 403 Forbiden

Control logico en MariaDB y estado final

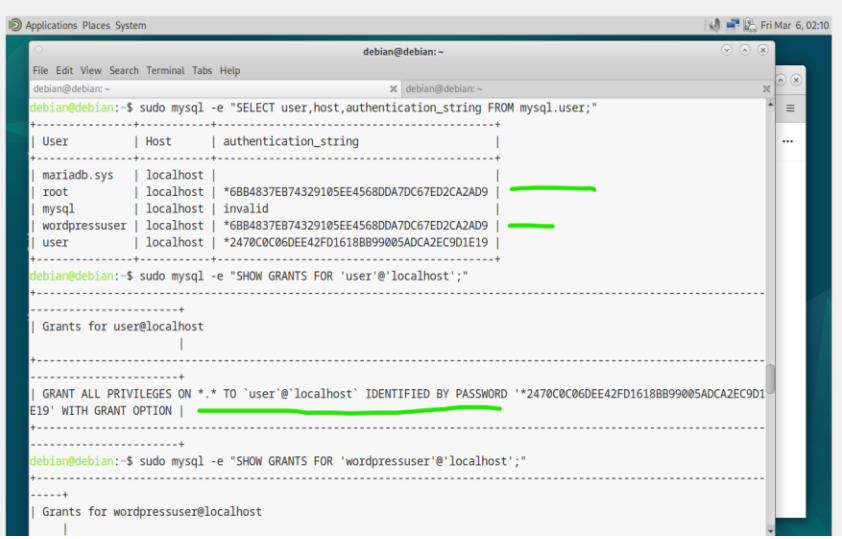
Se revisaron usuarios privilegiados y se confirmo continuidad operativa del sitio



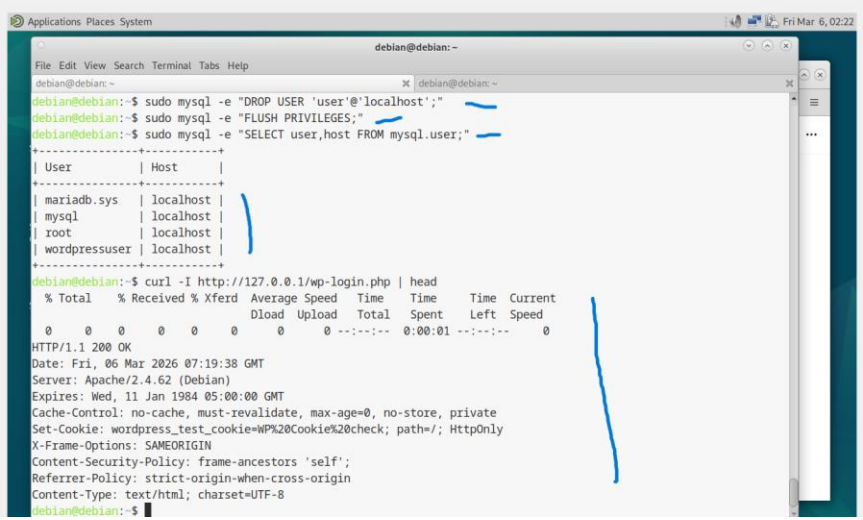
Se comprueba conexion MariaDB



Se buscan que usuarios hay en la DB



Se corroboran privilegios (ALL PRIVILEGES Y GRANT OPTION)



- Se elimina user
- Se comprueba eliminación
- Se comprueba conexión curl

Cierre técnico

- MariaDB no estaba expuesta a red, pero si existia riesgo por un usuario local innecesario con privilegios maximos.
- La eliminacion del usuario y FLUSH PRIVILEGES cerraron esa deuda de control.
- El sitio continuo operativo tras la limpieza y las validaciones de servicio.

Como responder ante un ataque similar y evitar recurrencia

Respuesta organizacional, roles y controles preventivos

Respuesta de la organizacion

T0 - Deteccion	SOC / admin detecta anomalias en logs, alertas o validaciones web.
T0 + 30 min	Se aísla el host o servicio afectado y se informa al responsable tecnico.
T0 + 2 h	Se ejecutan acciones de contencion: cierre de puertos, bloqueo de cuentas, snapshot y recoleccion de evidencia.
T0 + 24 h	Se comunica estado a management, se valida recuperacion y se documentan lecciones aprendidas.

Prevencion de recurrencia

Acceso remoto

Llaves publicas, MFA cuando sea posible, sin root por contrasena y allowlist administrativa.

Superficie web

Sin directory listing, minimo de plugins, WAF o reglas de hardening y actualizaciones programadas.

Monitorizacion

Escaneo recurrente, revision de logs, alertas de integridad y baseline segura documentada.

Gobierno

Responsables definidos, checklist de cambios y revision post incidente obligatoria.

Mecanismos de proteccion de datos

Backups, cifrado y controles de acceso para proteger informacion critica

1. Backups regulares

Backups automaticos de base de datos y archivos del sitio con politica 3-2-1, pruebas de restauracion y retencion definida.

2. Cifrado de datos sensibles

HTTPS/TLS para trafico web, cifrado de respaldos en reposo y resguardo de secretos fuera del codigo cuando sea posible.

3. Acceso minimo necesario

Cuentas separadas por rol, privilegios minimos en MariaDB, restriccion de sudo y revision periodica de permisos.

4. Integridad y trazabilidad

Centralizar logs, sellar cambios relevantes, conservar evidencia y tener versionado de configuraciones seguras.

Controles recomendados para este caso

- Respaldar wp-content y la base de datos antes de cambios criticos.
- Guardar copias fuera del servidor comprometible.
- Proteger wp-config.php y secretos de acceso con permisos estrictos.
- Revisar cuentas cada mes y eliminar accesos huérfanos.

ISMS propuesto basado en ISO 27001

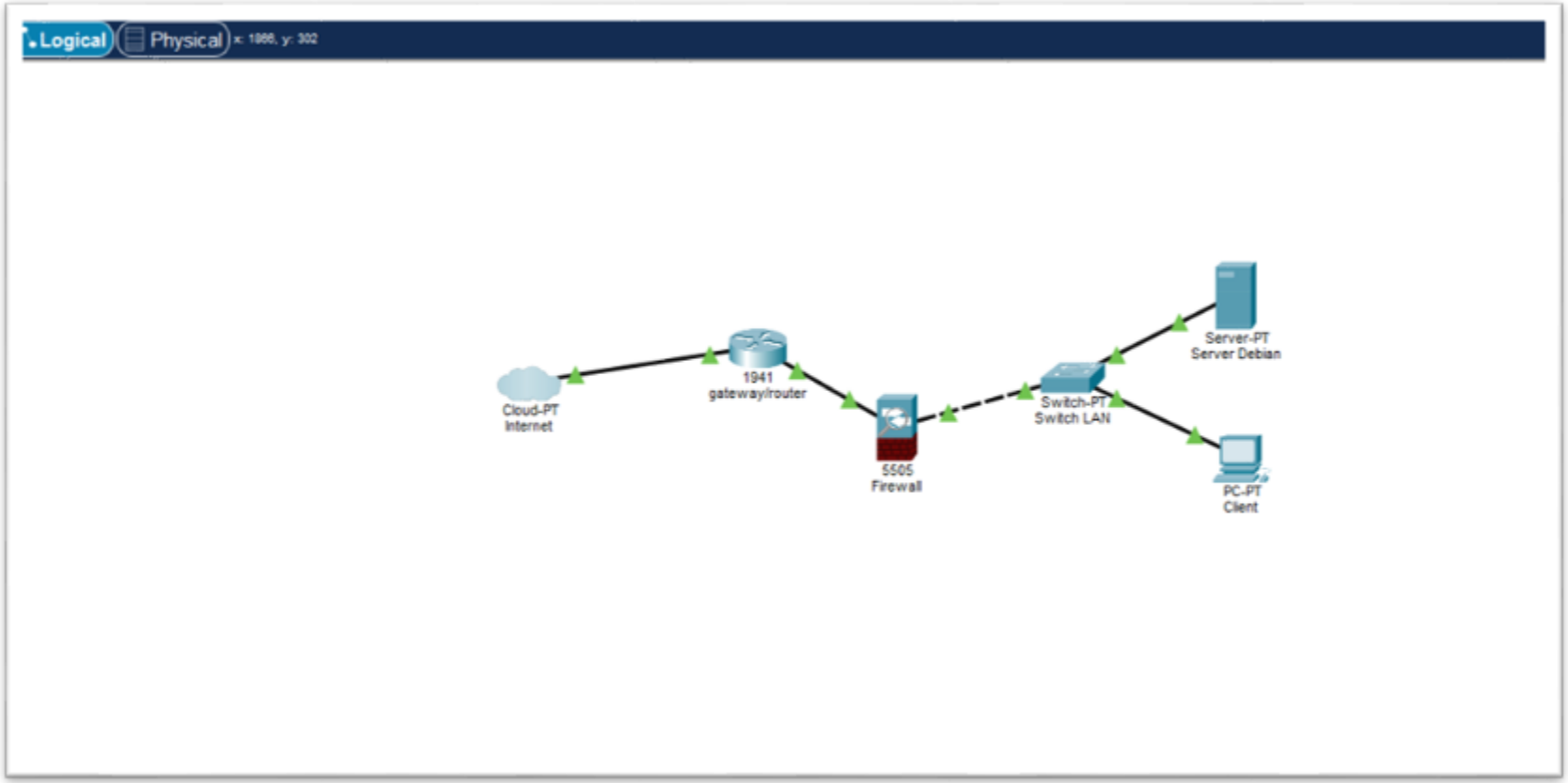
Como convertir hallazgos tecnicos en un sistema de gestion continuo

Alcance	Activos y riesgos	Politicas	Tratamiento	Seguimiento
Servidor Debian, WordPress, base de datos, acceso remoto y respaldos.	Identificar activos criticos, amenazas, vulnerabilidades e impacto de negocio.	Definir politicas de acceso, backups, cambios, hardening y respuesta a incidentes.	Priorizar acciones: cerrar brechas, asignar responsables y fechas objetivo.	Medir cumplimiento, revisar incidentes y mantener mejora continua.

Documentos minimos del ISMS

Contexto y alcance, inventario de activos, matriz de riesgos, politicas clave, statement of applicability, plan de tratamiento y registro de incidentes.

Mapa de red


Logical
Physical
Cloud-PT
Internet
1941
gateway/router
5505
Firewall
Switch-PT
Switch LAN
Server-PT
Server Debian
PC-PT
Client

Plan de recuperacion y continuidad

Se agrega para reforzar el entregable pedido: como restaurar servicios criticos tras un incidente

Prioridad de recuperacion

1. **Acceso administrativo seguro**
   Restablecer acceso SSH controlado y credenciales administrativas.
2. **WordPress y Apache**
   Levantar el front web con configuracion segura y validar disponibilidad.
3. **MariaDB**
   Restaurar DB desde backup verificado y confirmar consistencia del sitio.
4. **Monitoreo y logs**
   Reactivar trazabilidad para validar estabilidad y detectar recurrencia.

RTO / RPO sugeridos para el proyecto

RTO web
4 horas para recuperar servicio publico con configuracion segura.

RTO DB
6 horas si se requiere restauracion desde backup y validacion.

RPO
24 horas maximo de perdida aceptable.

Condiciones de exito

- Respaldos recientes y probados.
- Procedimiento documentado de restauracion.
- Roles definidos para decision tecnica y comunicacion.
- Checklist de validacion funcional despues del recovery.